

ARQUITECTURA DE SISTEMA BANCARIO

Alcance del sistema

El sistema bancario permitirá que los clientes del banco puedan revisar el histórico de movimientos de sus cuentas, realizar pagos y transferencias a cuentas propias, así como también a otros bancos y recibir las notificaciones de los movimientos realizados vía SMS y correo electrónico.

Los clientes del banco podrán hacer uso del sistema a través de una aplicación móvil y/o de una página web, las cuales permitirán al usuario realizar consultas de movimientos, pagos y transferencias. Todo esto será posible siempre que el cliente se haya registrado en el sistema bancario y haya pasado las validaciones de autorización y autenticación. La aplicación móvil también usará el reconocimiento facial como alternativa para acceder al sistema bancario.

El sistema cumplirá con los estándares de seguridad de la industria para proteger la información de los clientes y las diferentes interacciones que puede realizar con sus cuentas bancarias o productos. Esto incluye el uso de herramientas de detección de fraude, que pueden ser usadas en los flujos más críticos como: enrolamiento o registro en el sistema, pagos y transferencias.

El sistema tendrá la capacidad de recopilar y administrar los datos necesarios para mantener auditoría de todas las acciones que hagan los clientes del banco cuando usen el sistema. En ningún momento esta capacidad degradará el rendimiento del sistema.

La implementación del sistema debe cumplir con las normas legales del país en el cual se encuentra establecido el banco, sin perjuicio de aplicar normas y estándares internacionales como:

- Ley de protección de datos (Según norma legal del país)
- ISO-27001
- PCI-DSS
- Zero Trust
- etc

Objetivos y restricciones de arquitectura

La arquitectura propuesta para el sistema bancario busca los siguientes objetivos:

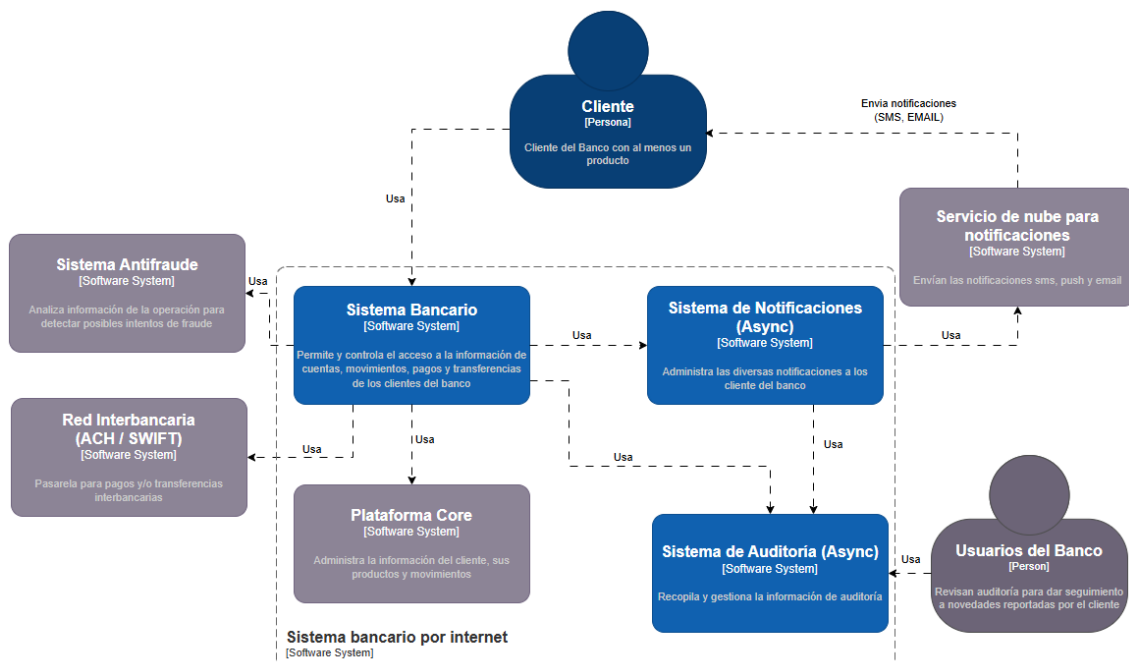
- Alta disponibilidad
- Escalabilidad
- Bajo acoplamiento
- Tolerancia a fallos
- Recuperación de desastres
- Seguridad y monitoreo
- Excelencia operativa
- Auto-healing
- Reusabilidad y cohesión de componentes

Diagramas

Código	Descripción
C1	Diagrama de Contexto del sistema bancario
C2	Diagrama de Contenedores
C2-01	Diagrama de Contenedores del sistema bancario
C2-02	Diagrama de Contenedores del sistema de notificaciones
C2-03	Diagrama de Contenedores del sistema de auditoría
C3	Diagrama de Componentes
C3-01	Diagrama de Componentes del sistema bancario
C3-02	Diagrama de Componentes del sistema de notificaciones
C3-03	Diagrama de Componentes del sistema de auditoría

C1- Diagrama de Contexto del Sistema Bancario

Este diagrama muestra como un cliente (usuario del sistema) utiliza el sistema bancario para acceder a su información, productos y movimientos y como el sistema bancario interactúa con los sistemas de notificaciones y de auditoría. Contempla la existencia de un usuario del banco que revisa y analiza la información de la auditoría para dar seguimiento a posibles novedades reportadas por los clientes que hacen uso del sistema bancario. Muestra también la interacción con el sistema antifraude y la red interbancaria.



Usuarios

Cliente: Usuario final registrado en el sistema bancario, el cual accede al sistema vía web o app, para realizar las transacciones económicas (pagos y/o transferencias) y consultas de movimientos.

Usuario del Banco: Usuario del banco que tiene acceso a datos de auditoría para monitorear o dar seguimiento a novedades reportadas por el cliente.

Sistemas Internos

Sistema Bancario: Brinda las facilidades, validaciones y controles para que un usuario pueda revisar los movimientos de sus cuentas, realizar pagos y/o transferencias de forma segura.

Sistema de Notificaciones: Permite la configuración, administración, preparación y envío de las diferentes notificaciones que el sistema bancario debe hacer llegar a los usuarios (sms, push y correo electrónico); como resultado de una transacción monetaria (pago o transferencia) o como parte de un flujo específico (enrolamiento o login) el cual requiera enviar notificaciones al cliente.

Sistema de Auditoría: Recopila, procesa, almacena y gestiona los datos necesarios para mantener auditoría de todas las acciones que realiza el usuario en el sistema bancario, de tal forma que puedan estar disponibles a los usuarios autorizados del banco para que puedan dar seguimiento a novedades reportadas por el cliente en el uso del sistema bancario.

Plataforma Core (On-Premise): Administra la información básica de los clientes del banco, sus productos y movimientos. Este sistema debe estar On-Premise para cumplir con las normas legales que generalmente rigen a los bancos.

Sistemas Externos

Sistema Antifraude: Analiza la información de cada operación para detectar posibles intentos de fraude.

Red Interbancaria: Se encarga de recibir y direccionar las transacciones a cuentas de otros bancos en el mismo país o cuentas en bancos de otros países.

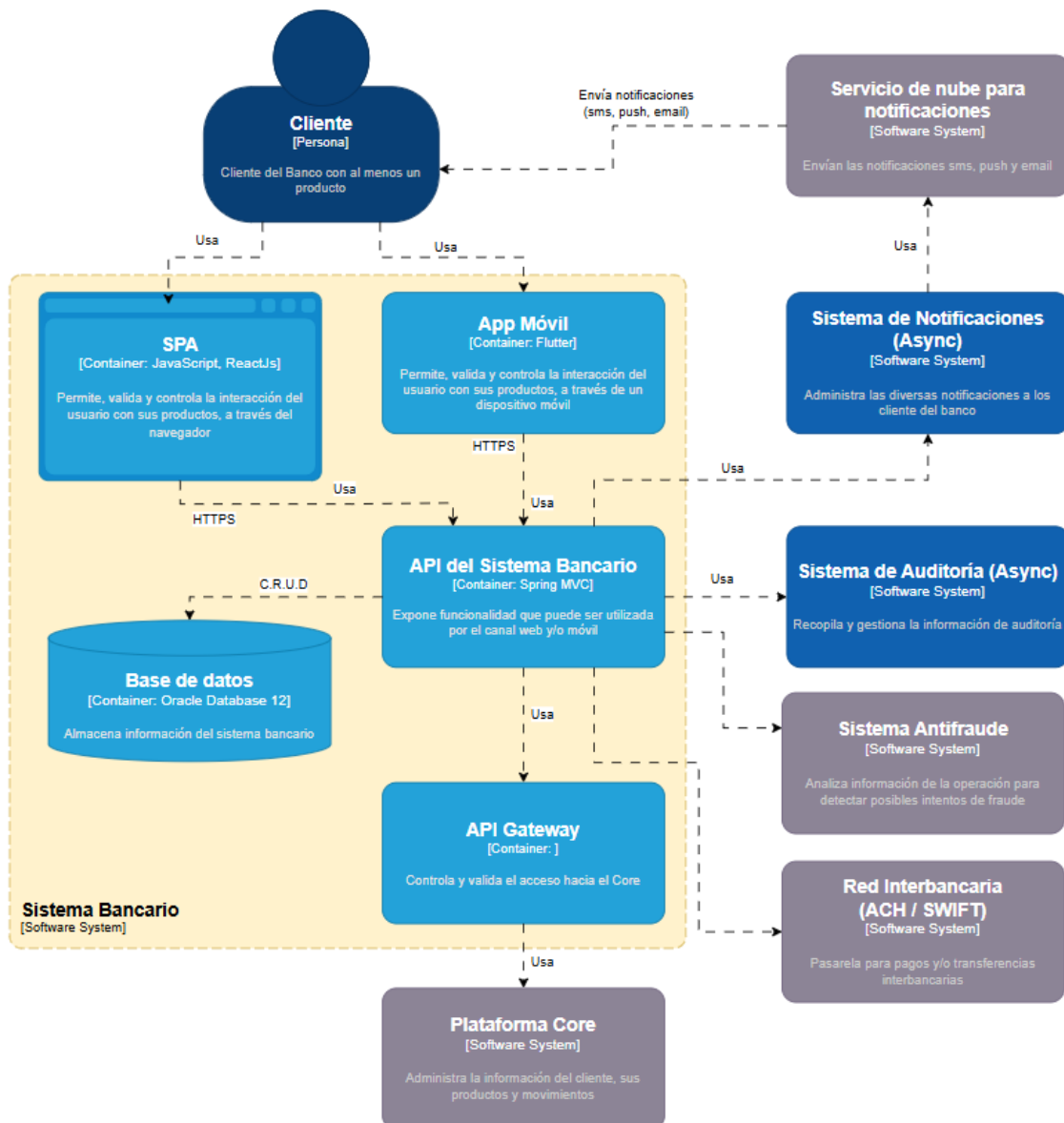
Consideraciones del Diseño

- La Plataforma Core debe mantenerse On-Premise para cumplir normativas que rigen a los bancos para mantener los datos críticos en infraestructura que esté bajo el completo control del banco.
- Se propone una arquitectura híbrida:
 - o On-Premise: Para mantener los datos críticos y sensibles en infraestructura controlada por el banco.
 - o Cloud para lograr la escalabilidad (y flexibilidad) requerida(s) ante el posible incremento de tráfico al liberar los canales: móvil (App) y web (SPA); bajo un esquema “controlado” de pago por uso de recursos de la nube.
- Se plantea un sistema asíncrono de notificaciones (sms, push y email) para garantizar la reusabilidad de su funcionalidad, bajo acoplamiento de los componentes y también para cubrir toda la complejidad (plantillas, redundancia de canales, integración con proveedores, etc) que pueden llegar a tener cada una de las notificaciones necesarias en los sistemas bancarios.
- Se plantea un sistema de auditoría que será asíncrono para mantener el alto desempeño esperado de un sistema bancario el cual también permitirá que usuarios del banco puedan acceder a dicha información para validar las acciones realizadas por los usuarios en el sistema bancario.

C1- Diagramas de Contenedores

C1-01 Diagrama de Contenedores - Sistema Bancario

El diagrama muestra como el cliente usa la SPA y/o la Aplicación Móvil para acceder a la funcionalidad que ofrece el sistema bancario a través de su API. Se aprecia dónde se almacenan los datos del sistema bancario y cómo utiliza el API-GATEWAY para obtener información de CORE.



Contenedores:

Single Page Application (SPA): Interfaz implementada en un navegador web para que el usuario pueda realizar consultas de movimientos, pagos y transferencias. Aquí se aplican las validaciones necesarias a la información que es ingresada por el usuario durante su interacción con el sistema.

App Móvil: Interfaz implementada para que el usuario pueda interactuar con el sistema, a través de un dispositivo móvil. Esta implementa validaciones a los datos ingresados por el usuario

durante su interacción con el sistema. Si el dispositivo móvil lo permite, la App móvil facilitará el reconocimiento facial y/o huella dactilar (datos biométricos) para ser utilizados en los procesos de autorización y autenticación del usuario en el sistema.

API del sistema bancario: Expone todas las funcionalidades que pueden ser consumidas por la página web (SPA) o la aplicación móvil, para que el usuario pueda interactuar con sus cuentas, haciendo consultas de movimientos, pagos y/o transferencias. Esta API permite mantener un acoplamiento débil con la capa de presentación (SPA y App).

API Gateway: Permite, controla y facilita el acceso a la información que se administra en el CORE.

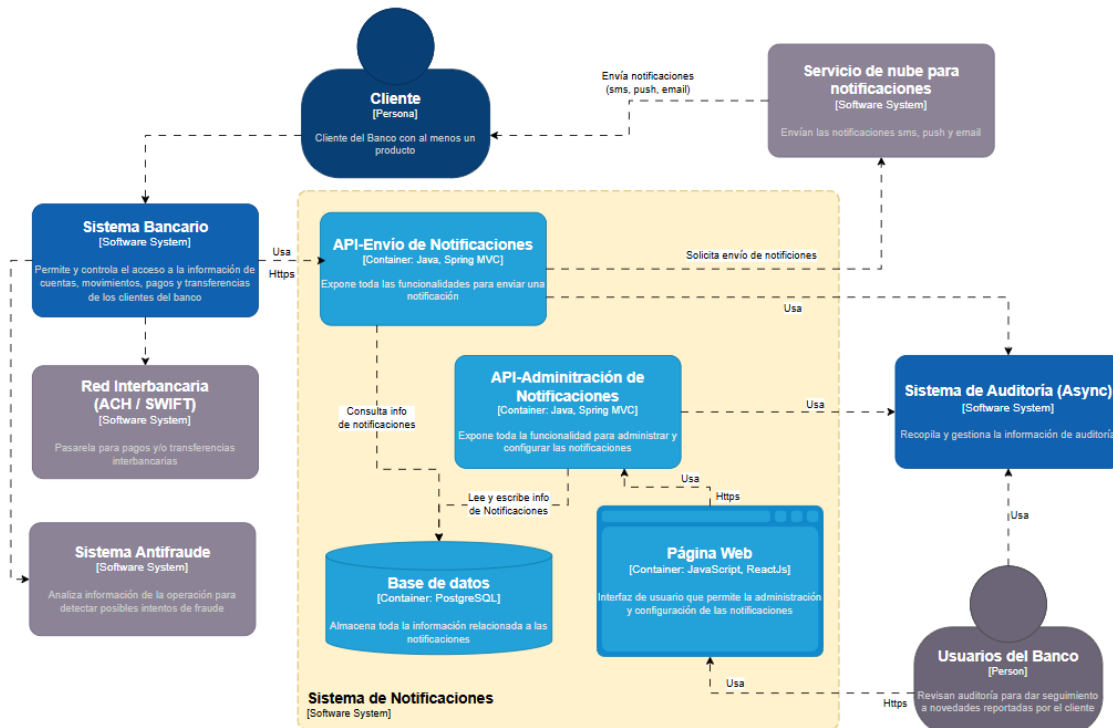
Base de datos: Almacena la información del sistema garantizando que esté disponible en cualquier momento para ser mostrada al usuario.

Consideraciones del Diseño

- Las conexiones desde la capa de presentación (SPA y App) hacia la API del sistema bancario se harán a través de HTTPS con TLS 1.3, para mantener segura la información en tránsito.
- La aplicación web (SPA) debe ser responsive y debe implementar mecanismos de protección contra XSS e inyección de SQL
- Se sugiere realizar la aplicación móvil utilizando Flutter por el gran soporte que brinda la comunidad. Se consideró otras plataformas como Outsystems pero ésta podría ser prohibitiva por los costos de sus licencias y los SLAs asociados a cada licencia.
- El uso de la Flutter para crear la App para Android como para iOS permite:
 - o Reducir el tiempo y costo de desarrollo
 - o Mejora la mantenibilidad de la App para las dos plataformas
 - o Garantiza la misma experiencia de usuario e iOS y Android
- La capa de presentación (SPA y App) estará desacoplada del backend a través del API del sistema bancario

C2-02 Diagrama de Contenedores - Sistema de Notificaciones

El diagrama muestra como el sistema bancario utiliza la API de envío de notificaciones para enviar una notificación (sms, push y email) al cliente. Para hacerlo la API de envío de notificaciones consulta la base de datos para obtener la plantilla y configuración de la notificación solicitada y luego solicita el envío de dicha notificación al servicio de nube para notificaciones el cual enviará un sms, push y/o email, según corresponda.



Contenedores

API-Envío de notificaciones: Se encarga de consultar, preparar y enviar la notificación que el sistema bancario haya solicitado. Esta API puede ser utilizada por otros componentes de la solución, permitiendo así la reutilización de las capacidades del sistema de notificaciones.

API-Administración de Notificaciones: Se encarga de exponer toda la funcionalidad necesaria para administrar y configurar las notificaciones de toda la solución. Esta API es utilizada por la página web a la cual tienen acceso los usuarios del banco

Página Web: Interfaz para los usuarios del banco que brinda las facilidades para administrar y configurar las notificaciones del sistema bancario, así como de otros componentes (actuales y futuros) de la solución.

Base de datos: Almacena la información relacionada con las notificaciones y la mantiene disponible para que sea gestionada por los usuarios del banco.

Servicio de nube para notificaciones: Se encarga de realizar la entrega de las notificaciones que solicita el sistema bancario (u otro sistema de la solución) a través del sistema de notificaciones. Estas notificaciones se entregan como sms, push (para los móviles) y email, según corresponda.

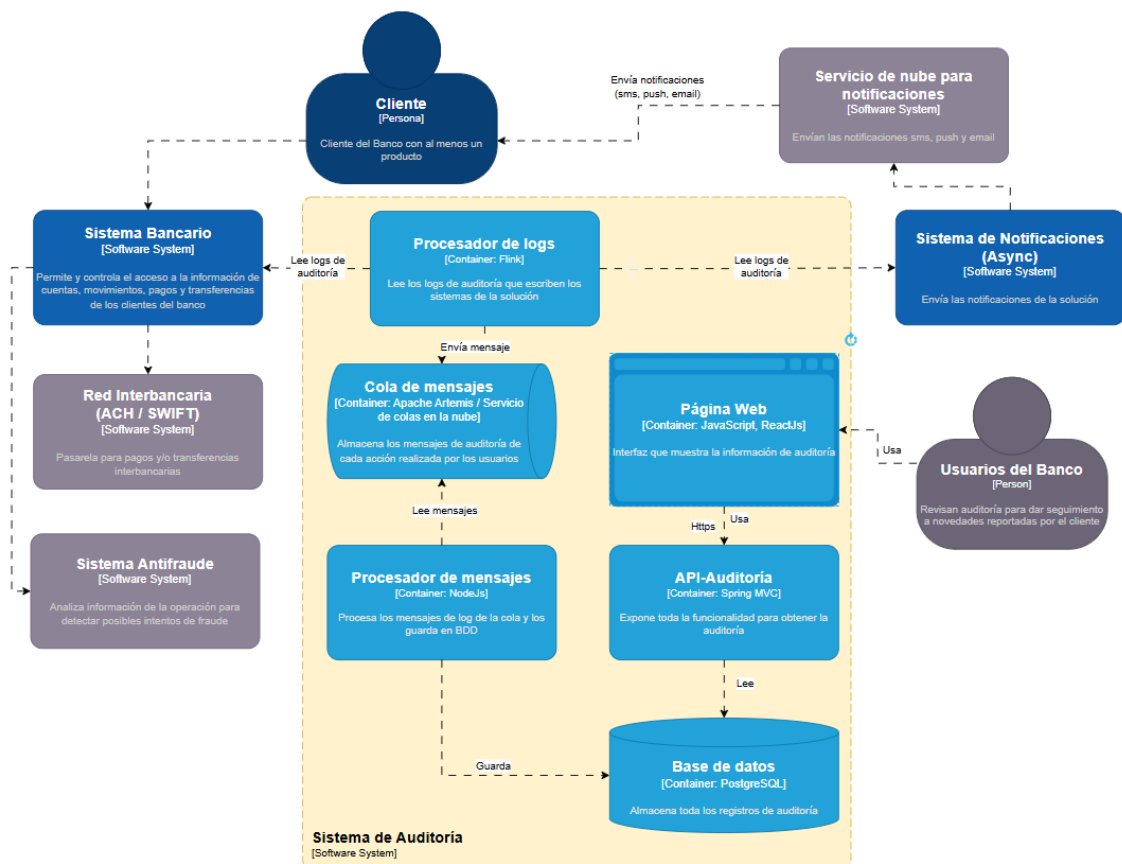
Consideraciones del Diseño

- Las conexiones hacia las APIs del sistema de notificaciones se realizarán por HTTPS con TLS 1.3
- Las APIs se implementarán con Spring MVC
- La base de datos a utilizar será PostgreSQL v17. Se consideró la base de datos Oracle 12 pero se descartó por tener un costo de licenciamiento superior al de PostgreSQL.
- La funcionalidad del sistema de notificaciones puede ser reutilizado por otros sistemas de la solución.

- El servicio de nube para las notificaciones deberá permitir el envío de notificaciones por SMS, PUSH en caso de la App y por email.
- Tanto la administración de notificaciones, como el envío de estas quedará registrado en el sistema de auditoría

C2-03 Diagrama de Contenedores - Sistema de Auditoría

Este diagrama muestra como el sistema de auditoría lee los logs de auditoría que escriben los sistemas: bancario y de notificaciones, para luego procesar dichos registros y almacenarlos en base de datos para que puedan ser consultados por los usuarios del banco para dar seguimiento a las novedades reportadas por los clientes



Contenedores

Procesador de logs: Se encarga de leer los logs de auditoría que escriben los sistemas de banco y de notificaciones; y de enviarlo a la cola de mensajes para ser procesados. Estas lecturas se hacen de forma asíncrona cada vez que roten los logs lo cual garantiza mantener bajo acoplamiento de los componentes de la solución y sin degradar el rendimiento de esta.

Cola de mensajes: Almacena los mensajes de auditoría para que sean procesados una sola vez por el “Procesador de mensajes”.

Procesador de mensajes: Lee los mensajes de auditoría de la cola de mensajes, los procesa, formatea, etc y persiste en la base de datos.

Base de datos: Almacena la información de auditoría y la mantiene disponible para que pueda ser visualizada por los usuarios del banco.

API-Auditoría: Expone toda la funcionalidad necesaria para que la información de auditoría pueda ser visualizada de forma rápida y segura, llegando a auditar también las acciones de los usuarios del banco.

Página web: Interfaz que brinda las facilidades para que el usuario de banco pueda visualizar la información de auditoría para dar seguimiento a novedades reportadas por el cliente.

Consideraciones del Diseño

- Los componentes están bajamente acoplados
- La funcionalidad puede ser fácilmente configurada para leer y procesar logs de auditoría de otros sistemas de la solución, permitiendo así reusabilidad de esta funcionalidad de la solución.
- Se mantiene el protocolo HTTPS con TLS 1.3 para las comunicaciones con la API de auditoría
- La auditoría se implementará con los patrones WORM (Write once – Read many) y Event Sourcing para habilitar procesos de recuperación ante desastres.
- La información de auditoría debe retenerse por el tiempo que exija la ley del país donde se encuentra el banco
- El acceso a la auditoría será restringido siguiendo el principio “Zero Trust”

C3- Diagramas de Componentes

C3-01 Diagramas de Componentes – API del Sistema Bancario

El diagrama muestra cómo interactúan los componentes del API del sistema bancario para que el usuario pueda realizar consultas de movimientos, pagos y transferencias.

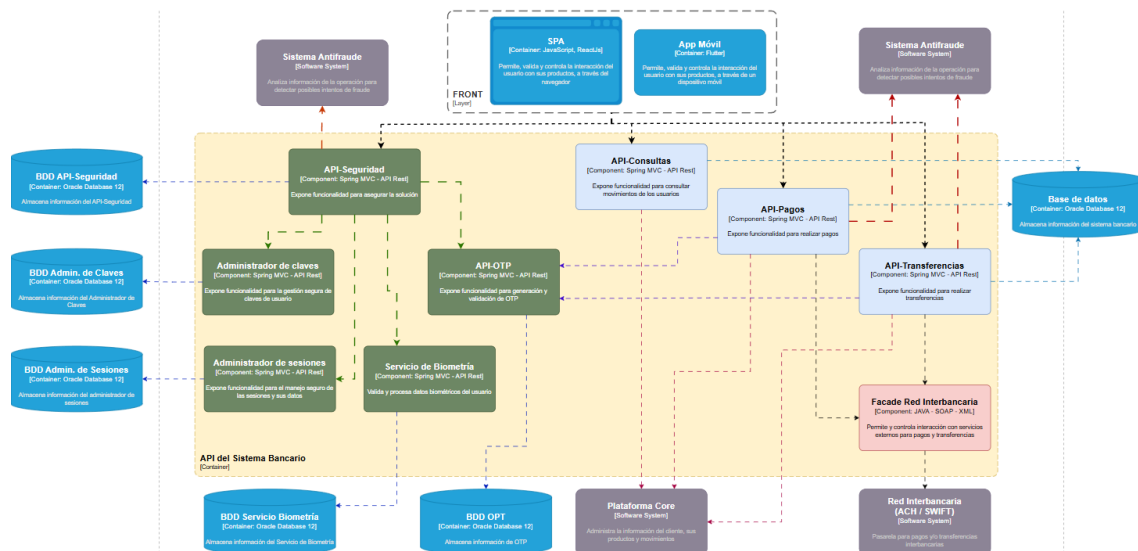
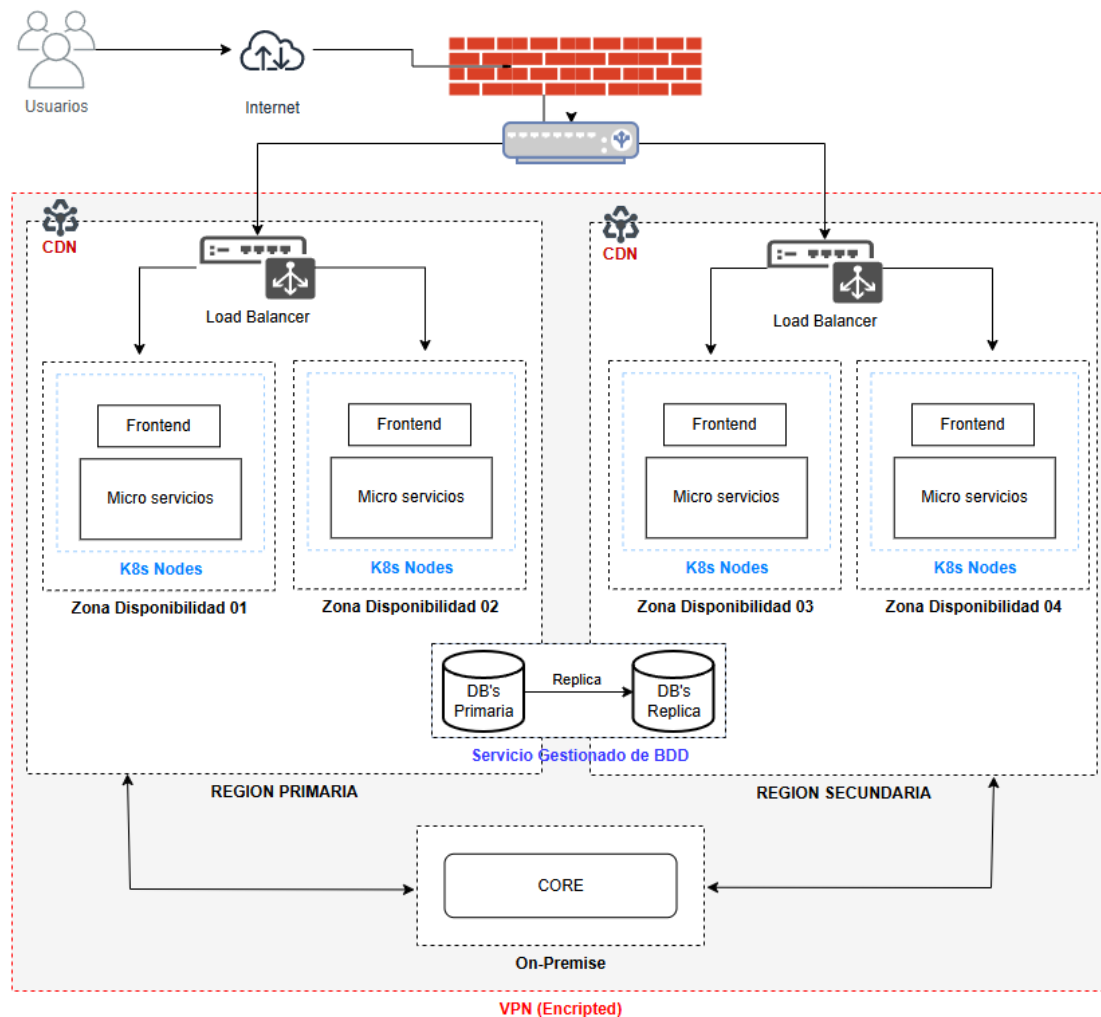


Diagrama de Despliegue

El diagrama muestra como interactúa el CORE alojado On-Premise con los demás componentes de la solución que se encuentran en la nube.



Con la arquitectura planteada se logra:

- Alta disponibilidad: Haciendo uso de diferentes zonas de disponibilidad de en dos regiones diferentes del proveedor de nube.
- Escalabilidad: Soportará incrementos aleatorios de tráfico creciendo/decreciendo de forma horizontal
- Bajo acoplamiento: Los componentes están diseñados para funcionar sin estar fuertemente acoplados a otros componentes.
- Tolerancia a fallos: El diseño de componentes en microservicios gestionados (K8s) permite levantar más instancias en caso de que una de ellas deje de funcionar. Por defecto el cluster de K8s se debe configurar para tener al menos 1 nodo funcionando.
- Recuperación de desastres: Las bondades de la nube permiten tener una Zona secundaria con toda la solución desplegada en "Stand by" y las bases de datos replicadas, de tal manera que en caso de desastre en la zona primaria se pueda redirigir el tráfico a la zona secundaria y garantizar la continuidad de la solución, cumpliendo con los SLAs.